

SAE3.CYBER.04 TP 3

Plate-forme Juice Shop

Le TP utilise la plate-forme <https://owasp-juice.shop/> : une application web Node.js / React avec de nombreuses vulnérabilités. Tout se passe via HTTP (pas HTTPS, il n'y a pas d'accès direct via SSH à la machine (inutile d'utiliser nmap pour avoir accès à d'autres services)).

Le code source de l'application est disponible sur GitHub, mais ici le principe est de travailler en boîte noire, sans connaître le code dans un premier temps. De plus, il y a un site très bien fait qui guide l'exploitation de Juice Shop et beaucoup d'utilisateurs qui diffusent des solutions. Il est demandé de ne pas se référer à ses sites et d'essayer de découvrir par soi-même.

Le but de l'exercice est de découvrir et savoir exploiter les vulnérabilités web manuellement. Il est donc demandé de ne pas utiliser les outils de type bruteforce, sqlmap, etc.. dans un premier temps.

1 Environnement

Votre système : utilisez Kali Linux afin de disposer de tous les outils nécessaires.
Sur Kali, installez Docker :

```
$ export http_proxy=http://cache-etu.univ-artois.fr:3128
$ sudo apt update
$ sudo apt install -y docker.io
$ mkdir /etc/systemd/system/docker.service.d
$ nano /etc/systemd/system/docker.service.d/http-proxy.conf
[Service]
Environment="HTTP_PROXY=http://cache-etu.univ-artois.fr:3128/"
Environment="HTTPS_PROXY=http://cache-etu.univ-artois.fr:3128/"
Environment="NO_PROXY=localhost,127.0.0.0/8"
$ sudo systemctl daemon-reload
$ sudo systemctl restart docker
$ sudo systemctl enable docker --now
$ docker
$ sudo usermod -aG docker $USER
```

Installez le Juice Shop OWASP :

```
$ sudo docker pull bkimminich/juice-shop
```

```
$ sudo docker run -d -p 127.0.0.1:3000:3000 bkimminich/juice-shop
```

Vous pouvez vous connecter au site Juice Shop sur <http://127.0.0.1:3000/#/>

Solution backup :

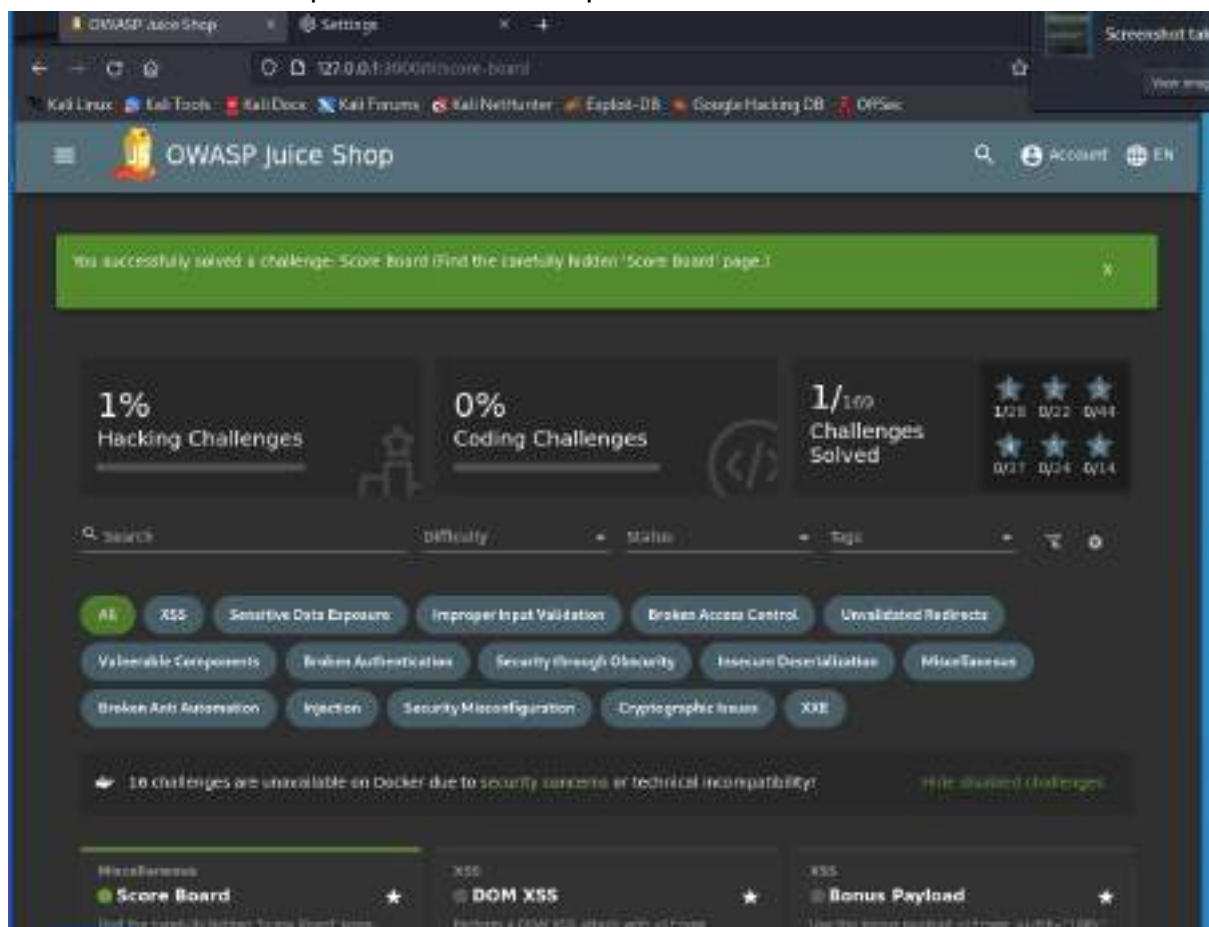
En cas de problème avec l'installation de Juice Shop et si aucune solution n'est trouvé,

vous pouvez utiliser le site suivant : <http://jsowasp.hackme.baby/>

2 Indications

Commencer par suivre le happy path, c'est-à-dire la navigation d'un utilisateur normal qui essaie les différentes fonctionnalités de l'application.

Énumérer toutes les vues et routes de l'application Juice Shop. Vous devriez trouver le tableau de scores qui sera nécessaire pour la suite.



Login as administrator : user : ' OR 1=1 --



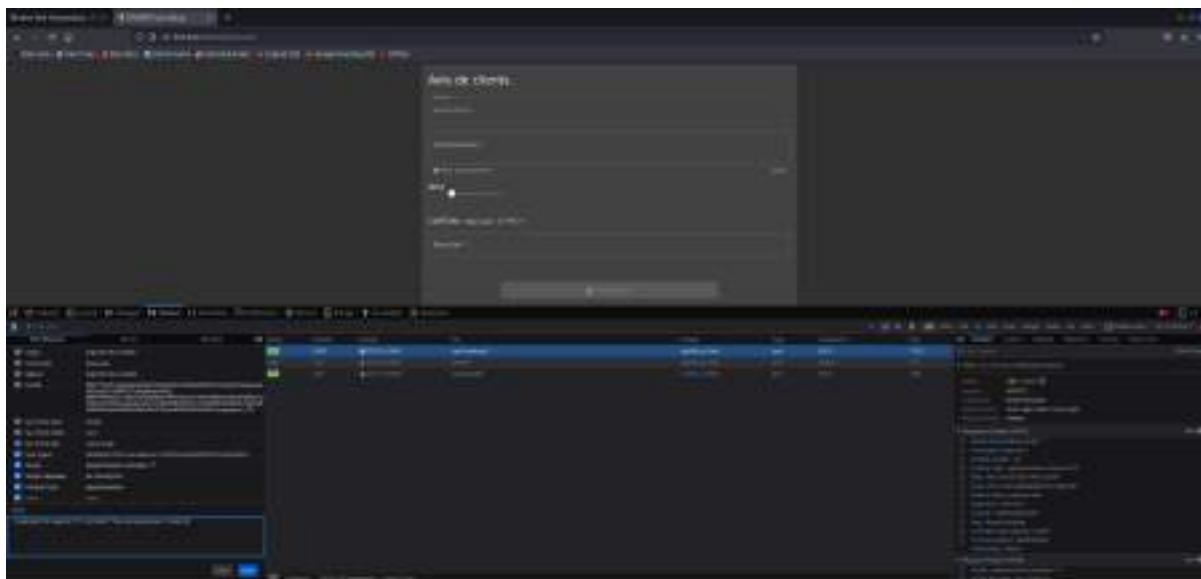
Bully chatBot :



fichier robot.txt voir ce qu'il y a l'intérieur



0 Étoiles



10 commentaire en moins de 20 sec
Il faut spam sent



Behave like any "white-hat"

http://127.0.0.1:3000/.well-known/security.txt

[illegible]

Outdated Allowlist

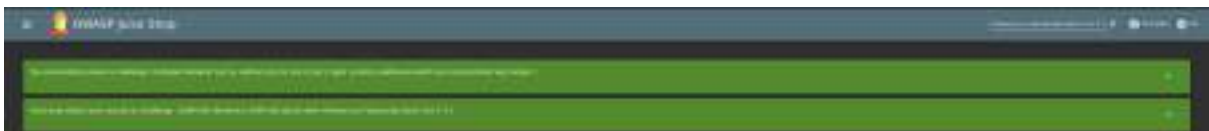
[/redirect?to=https://blockchain.info/address/1AbKfgvw9psQ41NbLi8kufDQTewG8DRZm](https://blockchain.info/address/1AbKfgvw9psQ41NbLi8kufDQTewG8DRZm)

```

}
showBitcoinQRCode() {
  this.dialog.open({
    data: {
      data: 'bitcoin:1A6fGwGpsQ41N6L18kuD6TcwGGR2s',
      url: 'https://tracint.top/blockchain/data/address/1A6fGwGpsQ41N6L18kuD6TcwGGR2s',
      address: '1A6fGwGpsQ41N6L18kuD6TcwGGR2s',
      title: 'TITLE_BITCOIN_ADDRESS'
    }
  })
}

```

DOM XSS



Bonus Payload



Mass Dispel

Shift plus clic on X

bjoern

Vous avez résolu avec succès un challenge : Bjoern's Favorite Pet (Reset the password of Bjoern's QWASP account via the Forgot Password mechanism with the original answer to his security question.)

Miss encode photo

<https://doi.org/10.1002/for.1455>

Login

Email *

mc.safesearch@juice-sh.op

Password *

Mr. Noodles



Forgot your password?

 Log in

☒ Remember me

1. Tester l'application et lister les fonctionnalités.
2. Trouver un moyen de se loguer sur l'application en tant qu'un autre utilisateur.
3. Créer un nouveau compte avec le rôle admin.
4. Exfiltrer le schéma de la base de données sans utiliser d'outils.
5. Trouver un moyen de payer sans mettre d'argent dans le wallet ou utiliser de CB
NB : pas de défis associé à cette étape dans le tableau des scores).
6. Récupérer un fichier sur la machine (utiliser la XXE.
7. Récupérer les données personnelles de quelqu'un d'autre.
8. Trouver un moyen de rediriger un utilisateur (open redirect).
9. Modifier un token JWT.

10. Continuez à évoluer dans les challenges.

NB : L'outil Burp vous sera fortement utile pour certaines étapes.
Merci de réaliser un compte rendu de TP afin de rendre compte de votre avancée.
Vous pouvez simplement y inclure les captures d'écran du score board des défis validés.

Alex:

<http://jsowasp-8.hackme.baby/#/score-board>

lisa :

<http://jsowasp-9.hackme.baby/#/score-board>